

HolicityFinance PHP 교회 재정관리 프로그램

전문 QA/UI 사용성 분석 리포트

코드 기반 화면 전환 도면 · 다중 단말 사용성 테스트 · 데이터 신뢰성/중복 사용자 검증 · 엔지니어 수정 요청서

항목	내용
대상 저장소	https://github.com/lmh8106/holicityfinance
작성 기준일	2026-05-17 (Asia/Seoul)
검토 방식	GitHub 공개 코드 정적 분석, 화면 흐름 추적, 모바일/태블릿/PC 반응형 시뮬레이션, QA test case 설계
중요 제한	저장소에 공통 include 파일, DB schema, seed data, excel_export.php 가 없어 완전한 서버 런타임 테스트는 불가능했습니다.
릴리즈 판정	Not Ready - 재정 데이터 신뢰성 결함과 실행 차단 결함이 있어 배포 전 P0 수정 필요

요약 결론

현재 코드는 화면 구성 아이디어는 있으나, 실제 교회 사용자가 PC/모바일/패드에서 안정적으로 쓰기에는 아직 위험합니다. 가장 큰 위험은 “재정 데이터가 잘못 합산되거나 다른 교회 데이터가 섞이는 문제”와 “동명이인/중복 입력 표시 문제”입니다. 사용성만의 문제가 아니라 재정 보고서의 신뢰성 문제로 이어집니다.

- P0: 누락 의존성/short tag/report_category 문법 때문에 실제 실행 환경 구축이 불완전합니다.
- P0: 수입/보고서 쿼리에 church_id 및 item_type/target_year 조인 조건이 누락되어 집계와 항목명이 틀릴 수 있습니다.
- P0: 동명이인 교인은 연간분석에서 member_name 기준으로 합산되어 개인별 보고서가 잘못 표시됩니다.
- P0: 수정/삭제/확정이 GET URL 로 수행되고 escaping 이 부족해 보안과 사용성 모두 위험합니다.
- P1: 모바일 하단 fixed 네비게이션/저장 버튼이 입력 UI 를 가릴 수 있고, 저장 후 화면 복귀가 사용자의 기대와 맞지 않습니다.

화면 전환 도면

아래 도면은 현재 코드상 주요 화면과 POST/GET 처리 페이지, 보고서/설정/누락 의존성의 관계를 요약한 것입니다.

굵은 빨간 경로는 사용자가 막히거나 잘못된 데이터를 볼 가능성이 높은 흐름입니다.



- 수입/보고서 다수 SQL에서 church_id, target_year, item_type 조인 조건이 빠져 다중 교회/다중 연도 데이터가 섞일 수 있습니다.
- 연간분석은 교인 선택값으로 member_id가 아니라 name을 사용하여 동명이인 한계가 병합됩니다.
- 모바일에서는 fixed bottom navigation과 fixed submit/action button이 하단 입력/버튼/목록을 가릴 수 있습니다.

테스트 범위

- 수입관리: income_main.php, income_record_process.php, income_manage_process.php, income_settings.php, income_settings_all.php
- 지출관리: expense_main.php, expense_process.php, expense_settings.php
- 보고서: report_annual.php, report_total.php, report_weekly.php, report_expense.php, report_category.php
- 단말 가정: PC 1440x900/1280x720, 태블릿 768x1024, 모바일 390x844/360x640, 모바일 키보드 표시 상태
- 검증 항목: 화면 전환, 동명이인/중복 입력 표시, 하단 UI 가림, 검색/필터/확정 일괄처리, 보고서 합계 신뢰성, 설정/삭제 안정성

저장소에 실행에 필요한 공통 파일과 DB 스키마가 없어 Apache/PHP/MySQL 기반 end-to-end 실행 테스트는 완료할 수 없었습니다. 따라서 본 리포트의 “동작 테스트”는 코드 흐름에 근거한 정적 실행 추적과, 동일 UI 구조를 복제한 Viewer 기반 시뮬레이션으로 수행했습니다. 이 제한은 결함이 없다는 의미가 아니라, 오히려 배포 전 재현 가능한 테스트 환경을 먼저 갖춰야 함을 뜻합니다.

TC	테스트 시나리오	단말	결과	비고
TC-01	저장소만 배포 후 income_main 접속	Desktop/Mobile	Fail	누락 include/DB 로 실행 불가 가능
TC-02	PHP short_open_tag=Off 환경에서 페이지 접속	All	Fail	<> 코드가 실행되지 않음
TC-03	report_category.php 문법 검사	All	Fail	중첩 PHP tag + db_conn.php 누락
TC-04	수입 화물 선택 없이 금액 입력 후 저장	Mobile	Fail	제출 후 alert: 사전 방지 없음

TC-05	과거 날짜 수입 입력 후 저장	All	Fail	저장 후 기본 income_main 으로 이동해 입력 내역이 안 보임
TC-06	동명이인 두 명의 수입 연간분석 조회	All	Fail	member_name 기준 필터로 합산
TC-07	미확정 검색/전체선택/확정	Mobile/PC	Fail	숨겨진 checked 항목 함께 제출 가능
TC-08	360x640 지출 일괄입력 하단 스크롤	Mobile	Warning	fixed 버튼/nav 가 마지막 필드 가림 가능
TC-09	미확정 수입 입력 후 주일보고서 출력	All	Fail	is_fixed/church_id 조건 없음
TC-10	확정 데이터 없는 기간 수지결산	All	Fail	50:50 비교 막대 표시
TC-11	수입 항목 추가/조회	All	Fail	item_type 누락으로 목록 미표시 가능
TC-12	항목명에 작은따옴표/태그 입력	All	Fail	JS/HTML escaping 미흡
TC-13	엑셀 저장 버튼 클릭	All	Fail	excel_export.php 누락
TC-14	모바일 확대/저시력 사용자	Mobile/Tablet	Warning	user-scalable=no
TC-15	사용 중 계정 항목 삭제	All	Fail	과거 내역 항목명/보고서 깨짐 가능

3. 모바일/패드 UI 가림 검증

지출 입력 화면은 bottom-nav와 저장 버튼이 모두 fixed 로 구현되어 있습니다. 작은 화면, 모바일 키보드, iOS safe-area, 태블릿 가로모드에서는 마지막 입력 필드와 하단 액션이 충돌할 수 있습니다. 수입 화면도 하단 네비게이션 뒤쪽에 엑셀/주일보고서 액션 카드가 있어 현재 탭과 무관하게 하단에 보이는 구조입니다.

모바일 UI 가림/고정 요소 리스크 재현

코드의 fixed bottom-nav, fixed submit button, sticky header 조합을 390px 폭 화면에 모의 렌더링했습니다.

문제

하단 네비게이션(.bottom-nav)과 지출 저장 버튼(.btn-bulk-submit)이 모두 fixed입니다. container padding-bottom은 120px뿐이라 작은 화면/가로모드/키보드 표시 시 마지막 입력 항목과 저장 버튼이 겹칠 수 있습니다.

권장 수정

1) 저장 버튼을 form 내부 sticky footer로 통합하거나 bottom 계산식을 CSS 변수로 관리합니다. 2) padding-bottom = nav 높이 + action 높이 + safe-area + 24px 이상. 3) 모바일 키보드 표시 상태에서 360x640 회귀 테스트를 추가합니다.

화면 전환 영향

수입관리에는 하단 nav 뒤에 엑셀/주일보고서 버튼 카드가 위치합니다. 현재 탭과 무관하게 DOM 하단에 노출될 수 있고, fixed nav 아래에 가려져 사용자가 버튼을 못 찾거나 잘못 누를 수 있습니다.

수정 기준

- 하단 nav 높이, action button 높이, safe-area 를 CSS 변수로 정의하고 본문 padding-bottom 에 합산합니다.
- 저장 버튼은 페이지 하단 fixed 보다 form 내부 sticky footer 또는 명확한 sticky action area 로 구성합니다.
- 360x640, 390x844, 768x1024, 1024x768 에서 마지막 입력 필드가 가려지지 않는 snapshot 테스트를 추가합니다.

4. 동명이인/중복 사용자 입력 및 표시 검증

수입 입력/관리 화면은 교인명과 생년월일을 일부 표시하지만, 연간분석에서는 option value 와 JS filter 기준이 이름 문자열입니다. 이름이 같은 교인이 여러 명이면 개인별 보고서가 합산됩니다. 재정관리에서는 “김민수 집사”와 “김민수 청년”이 다른 사람일 수 있으므로 이는 P0 로 분류해야 합니다.

중복 교인명/동일 사용자 입력 표시 리스크

코드상 연간분석은 member_id가 아니라 member_name 문자열로 필터링합니다. 같은 이름의 교인이 있을 때 합산/선택 오류가 발생합니다.

The screenshot shows a web application interface for church financial management. At the top, it says '전체 수입 합계 ₩ 300,000'. Below this is a section titled '교인 선택' (Select Member) with a dropdown menu. The dropdown menu is open, showing two options: '김민수 (집사)' (Kim Min-su, Pastor) and '김민수 (청년)' (Kim Min-su, Youth). Below the dropdown is a section titled '월별 추이 - 개인' (Monthly Trend - Individual) with two bars: '1월' (January) with a value of 100,000 and '2월' (February) with a value of 200,000. At the bottom, there is a red warning message: '※ 두 김민수의 수입이 하나로 합쳐짐' (※ The income of two Kim Min-sus is combined into one).

재현 시나리오

1) 같은 이름의 교인 A/B를 등록합니다. 2) A와 B에게 각각 수입을 입력/확정합니다. 3) 연간분석에서 “김민수”를 선택합니다. 4) 코드가 member_name === selected value 로 필터링하여 A/B가 합쳐집니다.

영향

교회 재정 보고서에서 개인별 현금/수입 내역이 잘못 귀속됩니다. 같은 이름이 많은 교회 환경에서는 매우 현실적인 결함이며, “동명이인” 표시와 필터 기준을 member_id로 바꿔야 합니다.

수정 기준

select option value는 member_id로 두고, 표시명은 이름 + 생년월일 + 직분을 사용합니다. 대시보드 데이터도 member_id를 포함해 JSON으로 전달하고, showTable/updateDashboard는 member_id로 필터링해야 합니다.

수정 기준

- 모든 개인 필터/링크/데이터셋은 member_name 이 아니라 member_id 를 기준으로 처리합니다.
- 화면 표시명은 이름 + 생년월일 + 직분을 함께 보여주며, 검색 data-name 에도 escape 된 보조 식별자를 포함합니다.
- 동일 member_id + item_code + date 의 반복 입력은 허용 정책을 명확히 정하고, 최소한 중복 경고/확인 메시지를 제공합니다.

5. 결함 목록 요약

ID	우선순위	영역	결함 요약
F-001	P0	실행/배포	공통 include 파일, DB 스키마, 엑셀 export 파일 누락으로 실제 구동 테스트가 차단됨
F-002	P0	실행/문법	대부분 파일이 short open tag(<?)를 사용하고 report_category.php 는 PHP 태그가 중첩됨
F-003	P0	데이터 분리	수입/보고서 쿼리에서 church_id 조건이 빠져 교회 간 데이터가 섞일 수 있음
F-004	P0	데이터 정확성	account_items 조인이 item_code 중심이라 항목명 중복/합계 뺄뺄 가능
F-005	P0	설정/데이터 손상	수입 항목 저장 시 item_type 이 빠지고 삭제 시 item_type 조건이 없어 목록/삭제 오류 발생
F-006	P0	동명이인/사용성	연간분석이 member_id 가 아니라 member_name 으로 개인을 필터링해 동명이인을 합산함
F-007	P0	보안/상태 변경	수정/삭제/확정/취소가 GET URL 로 실행되고 CSRF 방어가 없음
F-008	P0	보안/UI 깨짐	DB 값을 HTML/JS/속성에 직접 출력하여 XSS 및 특수문자 UI 오류 가능

F-009	P1	화면전환	수입 저장 후 선택 날짜/관리 탭으로 돌아가지 않아 “저장 안 됨”으로 오해 가능
F-010	P1	입력 UX	수입 항목을 선택하지 않아도 금액 입력이 가능하고, 오류는 제출 후에야 표시됨
F-011	P1	중복 입력	더블탭/재제출/동일 교인·항목·날짜 중복 입력 방지 장치가 없음
F-012	P1	검색/일괄확정	검색 후 전체선택 사용 시 숨겨진 체크박스가 함께 제출될 수 있음
F-013	P1	모바일 레이아웃	fixed 하단 네비게이션/저장 버튼이 작은 화면에서 입력 UI를 가릴 수 있음
F-014	P1	글로벌 헤더/Sticky	include 된 header_b.html 과 각 페이지 sticky header 가 top:0 에서 충돌할 가능성
F-015	P1	보고서 정확성	주일보고서가 church_id/is_fixed 조건 없이 날짜만으로 수입을 집계함
F-016	P1	보고서 UX	데이터가 없어도 수지결산 비교 막대가 50:50 으로 보여 오해 가능
F-017	P1	HTML/DOM	수지결산 인쇄 버튼의 closing button 태그가 누락되어 DOM 이 깨질 수 있음
F-018	P1	설정/데이터 보존	사용 중인 계정 항목 삭제 보호가 없어 과거 내역/보고서가 깨질 수 있음
F-019	P1	설정/통합계정	income_settings_all 의 REPLACE/DELETE 가 item_type 없이 item_code 기준이라 데이터 손상 가능
F-020	P1	연간분석 UX	차트 데이터가 없을 때 빈 영역만 표시되어 로딩 오류처럼 보임
F-021	P2	모바일/접근성	maximum-scale=1.0, user-scalable=no 로 확대가 제한됨
F-022	P2	시즌/기준정보	수입 시즌 값이 2026-1 분기/부활절로 하드코딩됨
F-023	P2	금액 입력	금액 수정 prompt 에서 실패 입력 시 intval 로 잘못 저장될 수 있음
F-024	P2	운영 안정성	display_errors=1 이 여러 페이지에 있어 운영 중 내부 오류가 사용자에게 노출됨
F-025	P2	네비게이션/정보구조	설정/보고서 메뉴 구조가 일관되지 않고 일부 페이지는 고아 페이지처럼 보임

6. 상세 결함 및 엔지니어 수정 요청

F-001 [P0] 공통 include 파일, DB 스키마, 엑셀 export 파일 누락으로 실제 구동 테스트가 차단됨

항목	내용
영역	실행/배포
근거	저장소 파일 목록에는 PHP 화면 파일과 README 만 확인되며 lib/config.php, inc/header_b.html, lib/auth_check.php, db_conn.php, schema, excel_export.php 가 보이지 않음. 여러 페이지는 해당 파일들을 include 함.
사용자/업무 영향	신규 서버/테스트 서버에서 첫 화면부터 500 오류 또는 include warning. QA/엔지니어가 동일 환경을 재현할 수 없음.
재현 절차	새 PHP 서버에 저장소만 배포 후 income_main.php 또는 expense_main.php 접속.
기대 결과	README 기반 설치, DB migration, seed data, 공통 include 가 모두 제공되어야 함.
수정 요청	schema.sql, .env.sample, install guide, lib/inc 파일 또는 의존성 안내를 추가. excel_export.php 를 구현하거나 버튼 제거.

F-002 [P0] 대부분 파일이 short open tag(<?)를 사용하고 report_category.php 는 PHP 태그가 중첩됨

항목	내용
영역	실행/문법
근거	income_main/expense_main/report_annual 등은 <?로 시작. report_category.php 는 <? 시작 후 닫지 않은 상태에서 다시 <?php 가 등장.
사용자/업무 영향	short_open_tag=Off 서버에서는 PHP 코드가 실행되지 않거나 노출됨. On 서버에서는 report_category.php 가 parse error 를 낼 수 있음.
재현 절차	short_open_tag=Off 환경에서 페이지 접속 또는 report_category.php 에 php -l 실행.
기대 결과	모든 PHP 파일은 <?php 및 <?=만 사용하고 php -l 을 통과해야 함.
수정 요청	전체 파일의 <?를 <?php 로 변경. report_category.php 의 중복 PHP 태그 및 db_conn.php include 를 제거/정리.

F-003 [P0] 수입/보고서 쿼리에서 church_id 조건이 빠져 교회 간 데이터가 섞일 수 있음

항목	내용
영역	데이터 분리
근거	income_main 의 수입 내역/교인별 합계, report_total, report_annual, report_expense, report_weekly 쿼리에 r.church_id 필터가 누락된 부분이 있음.

사용자/업무 영향	한 교회의 수입/지출 합계에 다른 교회 데이터가 포함되어 재정 보고서 신뢰성이 깨짐.
재현 절차	같은 DB 에 CHURCH_001/CHURCH_002 데이터를 넣고 동일 날짜/항목 보고서 조회.
기대 결과	모든 조회/수정/삭제는 세션 church_id 기준으로 격리되어야 함.
수정 요청	WHERE r.church_id = ?를 모든 레코드 쿼리에 추가하고 prepared statement 로 전환.

F-004 [P0] account_items 조인이 item_code 중심이라 항목명 중복/합계 뺄뉜기 가능

항목	내용
영역	데이터 정확성
근거	여러 보고서/목록에서 account_items 와 records 를 item_code 만으로 조인하거나 target_year 만 추가 하고 church_id/item_type 을 누락.
사용자/업무 영향	같은 item_code 가 다른 연도/교회/수입·지출에 존재하면 한 레코드가 여러 항목과 조인되어 합계가 중복될 수 있음.
재현 절차	2025/2026 또는 INCOME/EXPENSE 에 같은 item_code 를 넣고 report_total 조회.
기대 결과	조인은 church_id + target_year + item_type + item_code 로 제한되어야 함.
수정 요청	ON r.church_id=i.church_id AND r.item_code=i.item_code AND i.target_year=? AND i.item_type=? 형태로 수정. DB unique key 도 동일하게 설계.

F-005 [P0] 수입 항목 저장 시 item_type 이 빠지고 삭제 시 item_type 조건이 없어 목록/삭제 오류 발생

항목	내용
영역	설정/데이터 손상
근거	income_settings.php INSERT 는 item_type 을 넣지 않고, DELETE 는 church_id/year/item_code 만 조건으로 사용. 목록 조회는 item_type=INCOME 조건.
사용자/업무 영향	저장 후 목록에 보이지 않거나, 같은 코드의 지출 항목까지 삭제될 수 있음.
재현 절차	수입 항목 101 저장 후 목록 확인. 같은 코드의 EXPENSE 가 있을 때 수입 삭제.
기대 결과	수입 설정은 item_type=INCOME 으로 저장/조회/삭제되어야 함.
수정 요청	INSERT 컬럼에 item_type 추가, DELETE 에 AND item_type='INCOME' 추가.

F-006 [P0] 연간분석이 member_id 가 아니라 member_name 으로 개인을 필터링해 동명이인을 합산함

항목	내용
영역	동명이인/사용성
근거	교인 선택 option value 가 name 이고 updateDashboard 는 allData.filter(d => d.member_name === memberName)로 필터링.
사용자/업무 영향	동일 이름의 교인이 여러 명이면 개인별 수입 보고서가 잘못 표시됨. “똑같은 사용자” 입력/표시 문제의 핵심 결함.
재현 절차	김민수 두 명을 등록하고 각각 수입을 확인한 뒤 연간분석에서 김민수 선택.
기대 결과	동명이인은 생년월일/직분 등으로 구분 표시되고 내부 필터는 member_id 를 사용해야 함.
수정 요청	option value=member_id, JSON 에 member_id/birth_date 포함. 표시명은 이름+생년월일+직분.

F-007 [P0] 수정/삭제/확정/취소가 GET URL 로 실행되고 CSRF 방어가 없음

항목	내용
영역	보안/상태 변경
근거	income_manage_process 와 expense_process 는 GET action/id 로 edit/delete/fix/unfix/undo 를 수행. 설정 삭제도 GET.
사용자/업무 영향	링크 미리보기, 실수 클릭, 악성 페이지에 의해 재정 데이터가 변경될 수 있음. 확정 버튼 일부는 confirm 도 없음.
재현 절차	로그인 상태에서 /expense_process.php?action=fix&id=... URL 직접 호출.
기대 결과	상태 변경은 POST + CSRF token + 권한 검증 + 사용자 확인을 거쳐야 함.
수정 요청	GET action 제거, form POST 로 전환, CSRF token/session 검증 추가, 확정/취소 undo 제공.

F-008 [P0] DB 값을 HTML/JS/속성에 직접 출력하여 XSS 및 특수문자 UI 오류 가능

항목	내용
----	----

영역	보안/UI 깨짐
근거	member_name, item_name, target_name, category_name 등이 htmlspecialchars/json_encode 없이 출력되거나 onclick 문자열에 삽입.
사용자/업무 영향	O'Reilly 같은 이름만으로 수정 버튼 JS가 깨질 수 있고, 악성 입력은 XSS로 이어질 수 있음.
재현 절차	항목명에 작은따옴표 또는 <script> 유사 문자열 입력 후 설정/보고서 화면 조회.
기대 결과	출력 context 별 escaping 적용.
수정 요청	HTML은 htmlspecialchars(..., ENT_QUOTES, UTF-8), JS 인자는 json_encode(..., JSON_HEX_*), URL은 urlencode.

F-009 [P1] 수입 저장 후 선택 날짜/관리 탭으로 돌아가지 않아 “저장 안 됨”으로 오해 가능

항목	내용
영역	화면전환
근거	income_record_process.php는 성공 후 location.href='income_main.php'로 이동.
사용자/업무 영향	사용자가 과거 날짜에 입력하면 저장 후 오늘 기본 화면으로 이동해 방금 입력한 기록이 안 보임.
재현 절차	어제 날짜 선택 후 수입 입력 저장.
기대 결과	저장한 날짜의 확정 관리 탭으로 이동하거나 현재 입력 상태를 유지.
수정 요청	income_main.php?date=<income_date>&tab=manage로 redirect. HTTP 303 redirect 권장.

F-010 [P1] 수입 항목을 선택하지 않아도 금액 입력이 가능하고, 오류는 제출 후에야 표시됨

항목	내용
영역	입력 UX
근거	item_code hidden input은 칩 클릭 시만 설정. 금액 input은 항상 활성화.
사용자/업무 영향	여러 명 금액을 입력한 뒤 마지막에 alert가 떠서 사용자가 입력을 잃었다고 느낄 수 있음.
재현 절차	수입 항목 선택 없이 여러 교인 금액 입력 후 저장.
기대 결과	항목 선택 전 저장/금액 입력 비활성화 및 고정 안내.
수정 요청	선택 전 amount disabled, 선택된 항목 badge 표시, submit 전 client validation.

F-011 [P1] 더블탭/재제출/동일 교인·항목·날짜 중복 입력 방지 장치가 없음

항목	내용
영역	중복 입력
근거	income_record_process와 expense_process는 금액 > 0이면 매번 INSERT. 버튼 disable/토큰/중복 경고 없음.
사용자/업무 영향	모바일 더블탭 또는 저장 여부 혼동으로 같은 내역이 두 번 들어갈 수 있음.
재현 절차	입력 완료 버튼을 연속 두 번 탭하거나 브라우저 뒤로가기 후 재제출.
기대 결과	중복 제출 차단 또는 동일 조건 중복 경고.
수정 요청	submit 시 버튼 disable + idempotency token. 동일 member/item/date/amount 근접 중복 감지.

F-012 [P1] 검색 후 전체선택 사용 시 숨겨진 체크박스가 함께 제출될 수 있음

항목	내용
영역	검색/일괄확정
근거	toggleSelectAll은 현재 visible checkbox만 토글하지만, 이전에 체크된 hidden checkbox는 그대로 form에 남음.
사용자/업무 영향	사용자는 검색 결과만 확정한다고 생각하지만 이전 선택 내역까지 확정될 수 있음.
재현 절차	미확정 전체선택 → 이름 검색으로 일부 숨김 → 선택항목 확정.
기대 결과	현재 필터 범위만 제출되거나 숨김 전환 시 선택 상태를 명시적으로 관리.
수정 요청	필터 변경 시 hidden checked 해제, 선택 카운트 표시, “보이는 N건만 확정” 문구.

F-013 [P1] fixed 하단 네비게이션/저장 버튼이 작은 화면에서 입력 UI를 가릴 수 있음

항목	내용
영역	모바일 레이아웃
근거	expense_main은 bottom-nav와 btn-bulk-submit이 모두 fixed. income_main도 bottom-nav 뒤에 별도 action card가 배치됨.
사용자/업무 영향	모바일/패드/가로모드/키보드 표시 시 마지막 입력 필드나 액셀·주일보고서 버튼이 가려질 수 있음.
재현 절차	360x640 화면에서 지출 입력 목록 하단까지 스크롤하거나 iOS 키보드 표시.
기대 결과	하단 고정 영역 높이를 계산해 본문 여백이 충분해야 하며 액션 버튼은 탭/상태에 맞게 표시.

수정 요청	CSS 변수 --bottom-nav-h, --action-h 적용. padding-bottom: calc(var(...) + env(safe-area-inset-bottom) + 24px).
-------	--

F-014 [P1] include 된 header_b.html 과 각 페이지 sticky header 가 top:0 에서 충돌할 가능성

항목	내용
영역	글로벌 헤더/Sticky
근거	각 페이지는 header_b.html 을 include 하면서 내부 tab/header 도 top:0 sticky 또는 fixed 로 사용.
사용자/업무 영향	공통 헤더가 고정형이면 탭 메뉴가 가려지거나 두 헤더가 겹쳐 첫 입력 영역이 숨겨질 수 있음.
재현 절차	공통 헤더가 sticky/fixed 인 환경에서 income_main/expense_main 접속.
기대 결과	공통 헤더 높이를 CSS 변수로 정의하고 내부 sticky top 을 그 아래로 배치.
수정 요청	--global-header-h 를 header_b 에서 제공. .tab-menu { top: var(--global-header-h); }.

F-015 [P1] 주일보고서가 church_id/is_fixed 조건 없이 날짜만으로 수입을 집계함

항목	내용
영역	보고서 정확성
근거	report_weekly.php 의 query 는 r.income_date = date 조건만 있고 is_fixed/church_id 조건이 없음. 파일 내 church_id 도 하드코딩.
사용자/업무 영향	미확정 입력이나 타 교회 데이터가 공식 인쇄 보고서에 포함될 수 있음.
재현 절차	미확정 수입을 입력한 뒤 주일보고서 조회.
기대 결과	확정된 해당 교회 데이터만 보고서에 반영.
수정 요청	WHERE r.church_id=? AND r.income_date=? AND r.is_fixed=1. 하드코딩 church_id 제거.

F-016 [P1] 데이터가 없어도 수지결산 비교 막대가 50:50 으로 보여 오해 가능

항목	내용
영역	보고서 UX
근거	report_total.php 에서 total_sum=0 이면 inc_p=50, exp_p=50 으로 설정.
사용자/업무 영향	데이터 없는 기간을 수입/지출이 같은 것으로 오해할 수 있음.
재현 절차	확정 내역이 없는 기간을 조회.
기대 결과	빈 상태 메시지와 0 원 표시.
수정 요청	total_sum===0 이면 chart 숨김, “해당 기간 확정 데이터 없음” 표시.

F-017 [P1] 수지결산 인쇄 버튼의 closing button 태그가 누락되어 DOM 이 깨질 수 있음

항목	내용
영역	HTML/DOM
근거	report_total.php 의 인쇄 버튼은 <button ...> 텍스트 후 </button> 없이 div 가 닫힘.
사용자/업무 영향	브라우저가 자동 보정하지만 클릭 영역/레이아웃/인쇄 숨김 처리 오동작 가능.
재현 절차	report_total.php DOM inspector 에서 버튼 주변 노드 확인.
기대 결과	유효한 HTML 구조.
수정 요청	</button> 추가 및 HTML validator 를 CI 에 포함.

F-018 [P1] 사용 중인 계정 항목 삭제 보호가 없어 과거 내역/보고서가 깨질 수 있음

항목	내용
영역	설정/데이터 보존
근거	income_settings/expense_settings/income_settings_all 삭제 로직은 records 사용 여부를 확인하지 않음.
사용자/업무 영향	이미 기록된 수입/지출의 항목명이 NULL/미분류로 보이거나 보고서 누락.
재현 절차	기록에 사용된 계정 항목을 삭제 후 보고서 조회.
기대 결과	사용 중인 항목은 삭제 금지 또는 비활성화 처리.
수정 요청	삭제 전 count 조회. active flag 도입. 사용 중이면 “N 건 사용 중” 안내.

F-019 [P1] income_settings_all 의 REPLACE/DELETE 가 item_type 없이 item_code 기준이라 데이터 손상 가능

항목	내용
영역	설정/통합계정
근거	REPLACE INTO account_items 및 delete 는 item_code/year/church 기준 위주. item_code 입력도 intval/prepared 가 아님.
사용자/업무 영향	동일 코드의 수입/지출 항목이 서로 덮이거나 함께 삭제될 수 있음.
재현 절차	INCOME 101, EXPENSE 101 등록 후 통합 설정에서 101 수정/삭제.
기대 결과	수입/지출이 독립 키로 관리되어야 함.
수정 요청	unique key (church_id,target_year,item_type,item_code). UPDATE/INSERT 명시, DELETE 에도 item_type 포함.

F-020 [P1] 차트 데이터가 없을 때 빈 영역만 표시되어 로딩 오류처럼 보임

항목	내용
영역	연간분석 UX
근거	renderMonthChart 는 0 원 월을 모두 return 하고 empty-state 를 만들지 않음. renderItemChart 도 빈 container 를 유지.
사용자/업무 영향	사용자가 데이터가 없는지, 로딩 실패인지 구분할 수 없음.
재현 절차	확정 수입이 없는 기간으로 연간분석 조회.
기대 결과	“표시할 확정 수입 데이터가 없습니다” 안내.
수정 요청	data.length===0 또는 total===0 이면 empty message 렌더링.

F-021 [P2] maximum-scale=1.0, user-scalable=no 로 확대가 제한됨

항목	내용
영역	모바일/접근성
근거	여러 페이지 meta viewport 가 maximum-scale=1.0, user-scalable=no 를 사용.
사용자/업무 영향	고령 사용자/작은 화면 사용자가 금액/버튼을 확대하지 못함.
재현 절차	모바일 브라우저에서 pinch zoom 시도.
기대 결과	확대 가능한 viewport 와 충분한 touch target.
수정 요청	maximum-scale/user-scalable 제거, 최소 터치 대상 24x24 이상 및 실제 권장 44px 수준 버튼.

F-022 [P2] 수입 시즌 값이 2026-1 분기/부활절로 하드코딩됨

항목	내용
영역	시즌/기준정보
근거	income_main.php select option 이 2026-1 분기, 부활절만 제공.
사용자/업무 영향	연도 변경/교회별 절기 설정에 대응하지 못하고 사용자가 잘못된 시즌으로 기록할 수 있음.
재현 절차	2027 년 날짜 선택 후 수입 입력 화면 확인.
기대 결과	연도/교회별 시즌 설정 또는 자동 생성.
수정 요청	season table 도입. selected_date 기준 활성 시즌 로드.

F-023 [P2] 금액 수정 prompt 에서 쉼표 입력 시 intval 로 잘못 저장될 수 있음

항목	내용
영역	금액 입력
근거	income_manage_process 는 \$_GET[amount]에 intval 적용. edit prompt 는 자유 문자열.
사용자/업무 영향	1,000 입력 시 1 로 저장될 수 있음.
재현 절차	미확정 수입 수정 prompt 에 1,000 입력.
기대 결과	쉼표/공백 제거 후 숫자 검증.
수정 요청	POST modal form 으로 전환, preg_replace(/[^\d-9]/) 후 서버 검증.

F-024 [P2] display_errors=1 이 여러 페이지에 있어 운영 중 내부 오류가 사용자에게 노출됨

항목	내용
영역	운영 안정성
근거	income_main, expense_main, report_total, report_annual 등에서 error_reporting(E_ALL),

	ini_set(display_errors,1).
사용자/업무 영향	SQL 오류/경로/내부 구조가 사용자에게 보이고 화면이 깨짐.
재현 절차	DB 컬럼 누락 또는 쿼리 오류 발생.
기대 결과	운영은 display_errors=0, 로그만 기록.
수정 요청	APP_ENV 분기. 개발에서만 display_errors on.

F-025 [P2] 설정/보고서 메뉴 구조가 일관되지 않고 일부 페이지는 고아 페이지처럼 보임

항목	내용
영역	내비게이션/정보구조
근거	bottom-nav 설정은 income_settings.php 만 가리키고 expense_settings/report_expense/report_category 접근 흐름은 명확하지 않음.
사용자/업무 영향	엔지니어가 만든 기능이 사용자에게 보이지 않거나 사용자가 수입/지출 설정 위치를 혼동.
재현 절차	하단 메뉴만 사용해 지출 항목 설정 또는 카테고리 보고서 접근 시도.
기대 결과	설정 홈에서 수입/지출/통합계정/카테고리로 명확히 분기.
수정 요청	Settings landing page 추가. bottom-nav 는 설정 홈으로 연결.

7. 엔지니어 수정 우선순위 및 인수 기준

P0 - 배포 차단 수정

- 모든 PHP 파일의 short open tag 를 <?php 로 전환하고 php -l 전체 통과.
- schema.sql, seed data, .env.sample, lib/inc 공통 파일 또는 설치 문서 추가.
- 모든 수입/지출/보고서 쿼리에 church_id 필터 적용.
- account_items 조인을 church_id + target_year + item_type + item_code 로 수정.
- 동명이인 필터 기준을 member_id 로 변경.
- GET 상태 변경 제거, POST + CSRF token + 권한 검증 적용.
- 모든 HTML/JS/URL 출력에 context 별 escaping 적용.
- report_category 문법/의존성 수정 또는 메뉴에서 제거.

P1 - 데이터/사용성 안정화

- 저장 후 선택 날짜와 관리 탭으로 복귀.
- 수입 항목 선택 전 금액 입력/저장 비활성화.
- 중복 제출 방지 token, 버튼 disable, 중복 입력 경고 적용.
- 하단 fixed UI 의 safe-area/padding 계산 및 mobile snapshot 테스트.
- 사용 중 계정 항목 삭제 금지 또는 비활성화 전환.
- 보고서 empty-state 와 0 데이터 표시 수정.
- 주일보고서에 church_id + is_fixed 조건 적용.

인수 기준

기준	설명
A-01	저장소만으로 로컬 테스트 환경을 구성할 수 있다. README 에는 PHP/MySQL 버전, migration, seed, 계정 생성 절차가 있다.
A-02	php -l *.php 전체 통과. short open tag 사용 금지.
A-03	동명이인 2명 + 동일 날짜/항목 수입 입력 시 연간분석/관리 화면에서 각각 분리된다.
A-04	CHURCH_001/CHURCH_002 데이터를 함께 넣어도 각 교회 보고서 합계가 분리된다.
A-05	360x640/390x844/768x1024/1440x900 snapshot 에서 하단 nav/버튼이 입력 필드를 가리지 않는다.
A-06	삭제/확정/수정은 POST+CSRF 만 허용하고 GET 직접 호출은 상태를 바꾸지 않는다.
A-07	항목명/교인명에 작은따옴표, 따옴표, 꺾쇠가 있어도 UI 와 JS 가 깨지지 않는다.
A-08	확정 데이터 없는 보고서는 50:50 차트가 아니라 empty-state 를 보여준다.

부록 A. 권장 DB 키/쿼리 예시

account_items UNIQUE KEY 권장:
(church_id, target_year, item_type, item_code)

수입 항목 조인 예시:
LEFT JOIN account_items i
ON r.church_id = i.church_id
AND r.item_code = i.item_code
AND i.target_year = ?
AND i.item_type = 'INCOME'

동명이인 필터 예시:
<option value="<?= \$m['id'] ?>"><?= h(\$m['name']) ?> (<?= h(\$m['birth_date']) ?>, <?= h(\$m['job_title']) ?>)</option>
filtered = memberId ? allData.filter(d => String(d.member_id) === String(memberId)) : allData;

부록 B. 참조 파일/라인 범위/diagram

파일/범위	비고
저장소 파일 목록	README 와 PHP 파일 목록만 확인됨. lib/inc/schema/excel_export 없음.
income_main.php	수입 항목/내역/합계 쿼리, 입력/관리 탭, bottom-nav, excel_export 링크, GET edit/delete JS
expense_main.php	fixed submit button, bottom-nav, GET fix/delete/unfix 링크
income_settings.php	item_type 누락 INSERT, item_type 없는 DELETE
income_manage_process.php	GET edit/delete/undo_fix, select_fix POST
report_annual.php	member_name 기반 필터, JS innerHTML chart/table
report_total.php	church_id 없는 합계, zero data 50/50, unclosed print button
report_weekly.php	church_id hardcoded, is_fixed/church_id 없는 summary query
report_category.php	중첩 PHP tag, db_conn.php include, category query

income_main.php — 모바일 375px (수입 입력 탭)

HoliCity Finance 교회 재정관리 QA 분석 · 2026-05-18



발견된 문제

Critical UI-001: 엑셀/보고서 버튼 가림 하단 고정 네비(z-index:9999, 56px)가 '엑셀 저장'과 '주일보고서' 버튼 위를 덮어 터치 이벤트가 네비에 흡수됨. 핵심 내보내기 기능 사용 불가.
파일: income_main.php:328-331

Major DATA-001: 동명이인 구분 불가 '김영희(1990/03/15)' 2명이 시각적으로 동일하게 표시됨. member_id나 전화번호 끝자리 등 추가 식별 정보 필요.
파일: income_main.php:193

Major DATA-005: 항목 미선택 제출 가능 income_main.php에는 item_code 검증이 없어 항목 칩 미선택 시 빈 값으로 서버 전송 됨.
파일: income_main.php:186

Minor DATA-006: 시즌 하드코딩 '2026-1분기' 하드코딩. 매년 코드 수정 필요.

Minor RES-001: 금액 박스 고정폭 80px 고정이라 모바일에서 큰 금액 (1,000,000) 확인 어려움.

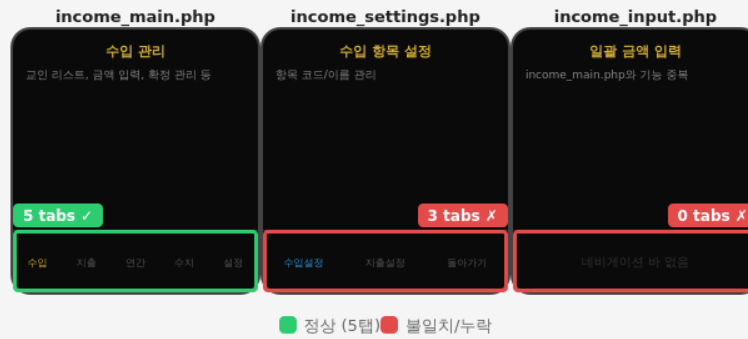
지출 입력 + 수입 확정관리 — 모바일 375px

겹침/터치 타겟/투명도/탭 리로드 문제

UI-008: opacity 가독성

UI-003: 하단 네비게이션 바 3개 페이지 비교

income_main(5탭) vs income_settings(3탭) vs income_input(0탭)



UI-003 결론: 설정 페이지에서 '연간분석', '수지결산' 등으로 바로 이동 불가. income_input.php는 네비 자체가 없어 브라우저 뒤로가기만 가능. 공통 bottom-nav.php를 include로 분리해야 함.

UI-005: 동일 기능 중복 페이지

income_main.php (수입 입력 탭)

birth_date 표시
item_code 검증 없음
htmlspecialchars 미적용
출식/전체 토글
하단 네비 5탭

income_input.php (독립 페이지)

birth_date 미표시
item_code onsubmit 검증
htmlspecialchars 적용
출식/전체 토글 없음
하단 네비 없음

UI-005 결론: 동일 기능이 2개 파일에 분산. 각각 장단점이 다름. 하나로 통합 필요.

보안 취약점 — GET 기반 데이터 변경 공격 경로

4개 Critical 보안 버그의 실제 공격 경로를 코드 수준으로 표시

SEC-005 수입 수정/삭제 (GET)

공격자 URL 생성

```
income_manage_process.php
?action=delete&id=15&date=2026-05-18
```

DELETE FROM income_records

WHERE id = 15

confirm() JS만 — 서버 검증 없음

POST + CSRF 토큰으로 변경

SEC-001 수입 금액 수정 (GET + SQL)

```
income_manage_process.php
?action=edit&id=1
&amount=0;DROP TABLE income_records--
```

```
$amount = intval($_GET['amount'])
```

intval()이 0으로 변환:

```
UPDATE ... SET amount = 0
```

금액이 0으로 변조됨

prepared statement + POST

SEC-002 수입 저장 (POST + SQL Injection)

```
income_record_process.php
POST: income_date=' OR 1=1; --
i 검증 없이 직접 삽입
INSERT INTO income_records
(..., ' OR 1=1; --', ...)
```

SQL 에러 → 에러 메시지 노출

(display_errors=1 → 데이터명 포함)

prepared statement + 날짜 형식 검증

SEC-006 보고서 권한 우회

```
report_annual.php
i 권한체크 코드 없음
$church_id = 'CHURCH_001' (하드코딩)
```

```
SELECT * FROM income_records
```

```
WHERE church_id = 'CHURCH_001'
```

```
const allData = [전체 교인 현금 내역]
```

i 브라우저 콘솔에서 열람 가능

세션 church_id + 권한체크 + API 분리

income_settings.php — 모바일 sticky 겹침

상단 121px가 고정되어 콘텐츠 영역이 좁아지는 문제



UI-011 모바일에서 헤더(51px)+입력폼 (70px)=121px 상단 고정. 전체 667px 중 18% 점유.

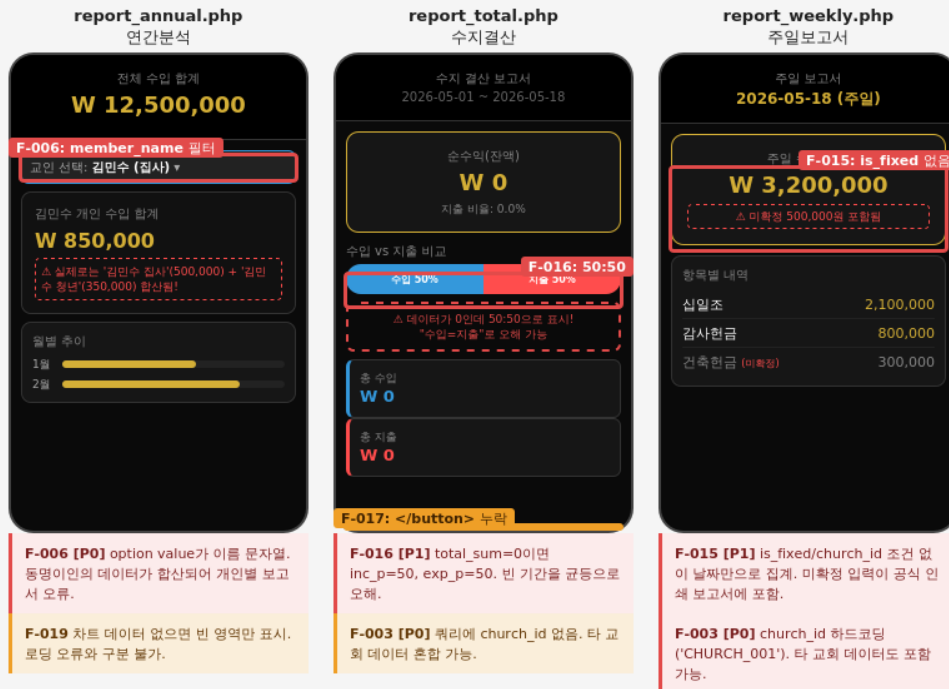
DATA-004 INSERT에 item_type 없음. 수입/지출 동일 코드 충돌 시 얹어쓰기.

SEC-005 삭제가 GET 방식. ? action=delete&code=101 prefetch로 오삭제 가능.

DATA-008 항목 삭제 시 연관 income_records 확인 없음. orphan 레코드 발생.

보고서 화면 3종 — 핵심 문제점 도면

연간분석(동명이인 합산) / 수지결산(50:50 빈 데이터) / 주일보고서(미확정 포함)



income_main.php 수입 입력 — 3종 디바이스 비교 (교인 리스트)

동일 화면이 375px / 768px / 1200px에서 어떻게 렌더링되는지



RES-001 @media 쿼리 전후. 375px에서 금액 input 100px 고정 → ~50px로 축소. 수정: flex 비율 기반 변경

RES-002 user-scalable=no. 모바일에서 핀치 줌 불가. WCAG 2.1 위반. 수정: 제거

PC 레이아웃 max-width:900px + position:fixed nav → 일부 브라우저에서 nav가 컨테이너 밖으로 확장

사용자 워크플로우 — 버그 발생 지점 매핑

수입 입력 → 확정 → 보고서 전체 흐름에서 어디가 끊기는지



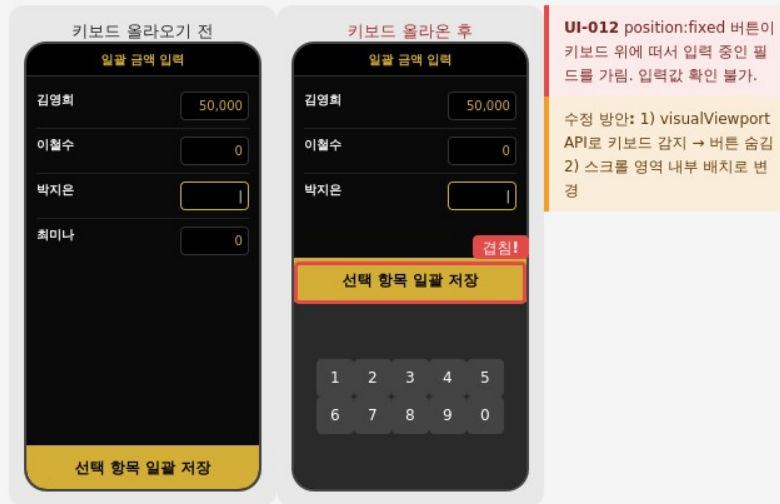
DATA-007: 전체선택 + 검색 필터 — 체크 상태 혼란

미확정 내역에서 전체선택 후 검색하면 의도하지 않은 항목이 확정되는 시나리오



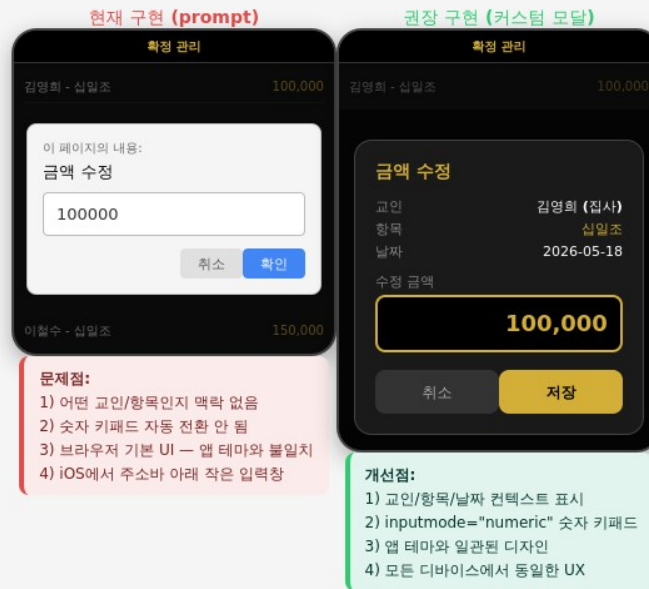
UI-012: 모바일 키보드 — 고정 버튼 겹침 (income_input.php)

position:fixed 버튼이 소프트 키보드 위에 떠서 입력 필드를 가리는 문제



UI-007: prompt() 수정 UX — Before vs After 비교

브라우저 기본 prompt()와 권장 커스텀 모달 비교



데이터 흐름도 — church_id / item_type / JOIN 조건 문제

F-003, F-004, F-005의 근본 원인과 영향 범위를 보여주는 다이어그램

account_items 테이블

church_id	year	type	code	name
CHURCH_001	2026	INCOME	101	십일조
CHURCH_001	2026	EXPENSE	101	교통비
CHURCH_002	2026	INCOME	101	십일조
CHURCH_001	2025	INCOME	101	십일조(구)

income_records 테이블

id	church_id	member_id	code	amount	fixed
1	CHURCH_001	10	101	100,000	1
2	CHURCH_002	20	101	200,000	1
3	CHURCH_001	10	101	50,000	0

JOIN 실행

현재 문제 report_total.php의 실제 쿼리

```
SELECT i.item_name, SUM(r.amount) as total
FROM income_records r
JOIN account_items i ON r.item_code = i.item_code -- church_id, year, type 없음!
WHERE r.income_date BETWEEN 'start_date' AND 'end_date'
-- r.church_id 필터 없음!
AND r.is_fixed = 1
GROUP BY r.item_code
```

결과: item_code=101 레코드 1건이 account_items 4행과 모두 조인

CHURCH_001의 수입 100,000원아:

- 십일조(INCOME 2026)와 조인 ✓
- 교통비(EXPENSE 2026)와 조인 ✗
- 타교회 십일조(CHURCH_002)와 조인 ✗
- 작년 십일조(2025)와 조인 ✗

→ SUM이 4배로 부풀려짐

수정 후 올바른 쿼리

```
SELECT i.item_name, SUM(r.amount) as total
FROM income_records r
LEFT JOIN account_items i
  ON r.church_id = i.church_id
  AND r.item_code = i.item_code
  AND i.target_year = ?
  AND i.item_type = 'INCOME'
WHERE r.church_id = ? -- 세션에서 가져온 값
AND r.income_date BETWEEN ? AND ?
AND r.is_fixed = 1
GROUP BY r.item_code
```

결과: CHURCH_001의 INCOME 2026 십일조만 정확히 조인

- 교회 격리 ✓ (church_id 필터)
- 수입/지출 구분 ✓ (item_type 조건)
- 연도 구분 ✓ (target_year 조건)
- prepared statement ✓ (SQL Injection 방지)

F-006: 동명이인 필터링 문제

member_name vs member_id 기준 필터링 비교

현재 member_name 기준

```
// report_annual.php JS
<option value="김민수">김민수 (집사)</option>
<option value="김민수">김민수 (청년)</option>

filtered = allData.filter(d =>
  d.member_name === "김민수"
) // → 두 사람 데이터 합산!
```

수정 후 member_id 기준

```
<option value="42">
  김민수 (1990/03/15, 집사)
</option>
<option value="78">
  김민수 (2001/07/22, 청년)
</option>

filtered = allData.filter(d =>
  String(d.member_id) === "42"
) // → 정확히 1명만!
```